

TEMA 3: Análisis de los incidentes de seguridad

TEMA 3: Análisis de los incidentes de seguridad

1. Concepto de los incidentes de seguridad
 - ¿Qué es un incidente de seguridad?
 - Suceso vs Incidente
 - Ejemplos de incidentes de ciberseguridad
 - Ciclo de vida de un incidente
 - Planificación y preparación
 - Detección y reporte
 - Valoración y decisión
 - Respuesta
 - Lecciones aprendidas
 - Actividad Post-Incidente
2. Clasificación de incidentes de seguridad.
 - Taxonomía de los incidentes
 - Factores para clasificar incidentes
 - Incidentes según su tipo
 - Clasificación de los incidentes
 - Niveles de peligrosidad
 - Niveles de Impacto
 - Beneficios de un sistema de clasificación de incidentes
3. Indicadores de compromiso
 - Definición
 - Tipos habituales de IoC
 - Clasificación de los indicadores
 - Identificación de los IoC
 - Creación de Reglas de Correlación y Casos de Uso
 - Técnicas Proactivas
4. Estrategias proactivas para prevenir incidentes de seguridad
 - Monitorización de Eventos de Seguridad y Fuentes de Datos
 - Procedimientos de Respuesta
 - Simulacros (Role-play) y Ciberejercicios
 - Equipos de Seguridad
 - Prevención y concienciación
5. Elaboración de informes sobre incidentes
 - Registro de incidentes
 - Estrategia de comunicación

6. Conceptos básicos del análisis forense

Métodos

Dispositivos encendidos

Dispositivos apagados

Cadena de custodia

Análisis de la evidencia digital

Análisis del malware

Recursos materiales

1. Concepto de los incidentes de seguridad

¿Qué es un incidente de seguridad?

- **Según la normativa ISO 270015:** Un incidente de seguridad de la información es "*Un evento o una serie de eventos de seguridad de la información no deseados o inesperados que tienen una probabilidad significativa de comprometer las operaciones comerciales y amenazar la seguridad de la información*".
- **INCIBE**, nos lo define de forma más simplificada: "*Cualquier suceso que afecte a la confidencialidad, integridad o disponibilidad de los activos de información de la empresa*"

Suceso vs Incidente

- **Suceso/Evento:** Es una ocurrencia detectada en el estado de un sistema, servicio o red que indica una posible violación de la política de seguridad o un fallo de los controles. Un evento puede afectar los niveles de riesgo, pero no afecta de forma necesaria al negocio o a la información.
- **Incidente de seguridad de la información:** Se refiere a algo que afecta de forma negativa tanto a los procesos del negocio como a la información.

Ejemplos de incidentes de ciberseguridad

- Accesos no autorizados a información (intrusiones, Amenazas Persistentes Avanzadas, etc.)
- Código dañino en los sistemas (gusanos, troyanos, virus, ransomware, rootkits, etc)
- Código no autorizado en los sistemas corporativos (por ejemplo, software pirata)
- Ataques remotos (denegación de servicio, etc)
- Ataques a los contenidos (distribución de contenido fraudulento o malicioso, etc)

Los incidentes de ciberseguridad no siempre son causados por actores hostiles, sino que también pueden estar asociados a accidentes o errores no intencionados.

Es habitual encontrar a diario en prensa noticias sobre incidentes de ciberseguridad que comprometen las actividades de las organizaciones o los datos de los ciudadanos, como los prolíficos ataques por ransomware (secuestro de información a cambio de beneficio económico), ataques de denegación de servicio, ataques a cadena de suministro (Supply Chain Attack), ciberespionaje, campañas de phishing, etc. Y es que, existe una gran variedad de ciberamenazas por las que un actor hostil puede alcanzar sus objetivos o motivaciones:

- Ciberespionaje (robo de información en beneficio propio o de un tercero como un Estado u organización).
- Ciberdelito (beneficio económico, daño reputacional, etc.).
- Ciberterrorismo (provocación de daños en el plano físico, ataques a infraestructuras críticas, etc.).
- Ciberactivismo (reivindicación ideológica, protesta, etc.).
- Ciberguerra (superioridad en el ciberespacio...).

Ciclo de vida de un incidente

- Para la mayoría de la gestión de los incidentes se describen una serie de etapas para un manejo adecuado de los mismos.
- Estas etapas se resumen en una etapa de preparación ante cualquier incidente, la etapa de detección y análisis de incidentes, la etapa de contención o recuperación y la etapa pos-incidente.
- PREPARACIÓN - DETECCIÓN - CONTENCIÓN / RECUPERACIÓN - POS-INCIDENTE
- La norma ISO / IEC 27035 presenta una guía para la localización, análisis y evaluación de vulnerabilidades e incidentes a los que puede estar expuesta una organización.

Planificación y preparación

- En esta fase, se establecen meticulosamente los procesos, procedimientos y recursos necesarios para afrontar incidentes de ciberseguridad. Se elaboran planes de respuesta detallados, asignando roles y responsabilidades específicos a los miembros del equipo. Además, se llevan a cabo simulacros y entrenamientos periódicos para asegurar la eficacia y cohesión del equipo ante situaciones de amenaza.

Detección y reporte

- Durante esta etapa, los sistemas de monitoreo se mantienen activos las 24 horas del día para identificar cualquier actividad inusual o indicador de compromiso. La detección de posibles amenazas desencadena el proceso de reporte, donde se recopilan datos relevantes, se documenta el incidente y se notifica de manera inmediata a los responsables, iniciando así el flujo de respuesta.

Valoración y decisión

- Tras la detección, se realiza una evaluación exhaustiva del incidente. Se determina la naturaleza y gravedad del evento, identificando las posibles amenazas y evaluando el impacto en la seguridad. Con esta información, se toman decisiones informadas sobre las medidas que deben implementarse para contener, mitigar y resolver el incidente.

Respuesta

- En esta fase, se ejecutan las acciones delineadas en el plan de respuesta. Esto puede incluir la contención de la amenaza, la identificación y eliminación de malware, la restauración de sistemas desde copias de seguridad seguras, y la colaboración con equipos internos y externos para gestionar eficazmente la crisis.

Lecciones aprendidas

- Después de manejar el incidente, se realiza un análisis en profundidad. Se revisan las acciones tomadas, se evalúa la eficacia de la respuesta y se identifican áreas de mejora. Las lecciones aprendidas se documentan meticulosamente, proporcionando valiosos conocimientos que se incorporarán al proceso de mejora continua de la gestión de incidentes.

Actividad Post-Incidente

- En la fase final, se llevan a cabo actividades destinadas a la normalización de las operaciones. Se actualizan registros y documentación, se comunican las lecciones aprendidas a todo el equipo, se implementan ajustes en los procedimientos según sea necesario y se completa un informe detallado del incidente para fines regulatorios y referencia futura. Esta fase cierra el ciclo de gestión de incidentes, pero también alimenta la fase de planificación y preparación para futuros eventos.

2. Clasificación de incidentes de seguridad.

Taxonomía de los incidentes

- La taxonomía de incidentes es una clasificación de los tipos de incidentes de seguridad que una organización debe gestionar.
- Su objetivo es facilitar el análisis, la contención y la erradicación de estos incidentes, permitiendo una respuesta más organizada y eficaz.
- Cada organización debe desarrollar una taxonomía adaptada a sus necesidades, aunque se recomienda seguir guías de referencia comunes.
- **Desafíos:**
 - No es tarea sencilla: Clasificar incidentes puede ser complejo debido a las múltiples formas en que los ataques pueden ocurrir.
 - Diversidad de enfoques: No existe una única forma correcta de clasificar los incidentes, por lo que muchas organizaciones desarrollan sus propias taxonomías internas.
- **Guías:**
 - Según la Guía de Seguridad de las TIC CCN-STIC 817 del Esquema Nacional de Seguridad, al clasificar incidentes de ciberseguridad se deben considerar factores como el tipo de amenaza, su origen, la seguridad de los sistemas afectados, el perfil de los usuarios comprometidos y el impacto en la organización.
 - La ENISA (Agencia de la Unión Europea para la Ciberseguridad) ha publicado documentos clave sobre la clasificación de incidentes, destacando el "Reference Incident Classification Taxonomy" (2018), que sirve de base tanto para la Guía CCN-STIC 817 como para la Guía Nacional de Notificación y Gestión de Ciberincidentes.

Factores para clasificar incidentes

1. **Tipo de amenaza:** Se refiere a la naturaleza del incidente y qué tipo de ataque o amenaza lo provoca. Los tipos de amenazas pueden incluir: Código dañino/malware, Ingeniería Social, Acceso no autorizado, Ataques de denegación, etc.
 - Ejemplo: Un ataque de ransomware que bloquea el acceso a los sistemas corporativos hasta que se pague un rescate es un ejemplo de código dañino/Malware.

2. **Origen de la amenaza:** Este factor identifica la fuente del incidente. Puede clasificarse en amenazas externas (fuera de la organización: ciberdelincuentes), internas (dentro de la organización, empleados maliciosos, ex-empleados) , errores humanos, o amenazas mixtas.
 - Ejemplo: Un empleado que, por accidente, abre un archivo malicioso en un correo phishing es un ejemplo de una amenaza con origen en errores humanos
3. **Impacto en la organización:** Se evalúa el nivel de afectación que el incidente tiene sobre los sistemas y la información de la organización. (CIA- Confidencialidad, Integridad y Disponibilidad)
 - Ejemplo: Un ataque DDoS que deja inaccesibles los servidores de una empresa afecta a la disponibilidad
4. **Perfil de los usuarios comprometidos:** El nivel de compromiso de un incidente puede variar según el tipo de usuario afectado:
 - Usuarios privilegiados: Administradores o personal con acceso a datos sensibles y control sobre los sistemas.
 - Usuarios comunes: Personal o clientes con acceso limitado.
 - Ejemplo: Si un atacante compromete una cuenta de administrador, el impacto es mucho mayor que si compromete una cuenta de usuario regular, debido al acceso privilegiado a datos críticos y configuraciones del sistema.

Incidentes según su tipo

- **Incidentes relacionados con contenido abusivo**
 - **Spam:** Correo electrónico masivo no solicitado que puede saturar los sistemas de correo.
 - **Delito de odio:** Contenido difamatorio o discriminatorio que puede incluir ciberacoso o amenazas dirigidas a colectivos o individuos.
 - **Pornografía infantil o contenido violento:** Material visual que promueva la violencia o contenga contenido sexual inapropiado, como la pornografía infantil.
- **Incidentes relacionados con código dañino .**
 - **Sistema infectado:** Un sistema comprometido con malware, como virus, troyanos, o spyware.
 - **Servidor de C&C (Command and Control):** Contacto de los sistemas infectados con un servidor de mando y control, que recibe instrucciones y envía datos robados.
 - **Distribución de malware:** Recursos que se usan para distribuir malware, o sistemas que almacenan archivos de configuración de malware
- **Incidentes de obtención de información**

- **Escaneo de redes:** Envío de solicitudes a sistemas para descubrir información sobre tecnología utilizada, servicios, o vulnerabilidades.
- **Sniffing (análisis de paquetes):** Observación e interceptación del tráfico de red para obtener información sensible.
- **Ingeniería social:** Engañar a personas para que revelen información confidencial a través de bulos, correos falsos, o suplantaciones
- **Intentos de intrusión:**
 - **Explotación de vulnerabilidades conocidas:** Intento de comprometer un sistema aprovechando vulnerabilidades conocidas, a menudo identificadas mediante CVE (Common Vulnerabilities and Exposures)
 - **Acceso con vulneración de credenciales:** Uso de técnicas como ataques de fuerza bruta para obtener contraseñas y acceder al sistema
 - **Ataques desconocidos:** Ataques utilizando exploits nuevos o poco documentados, difíciles de detectar.

Clasificación de los incidentes

- Para una gestión efectiva de incidentes de ciberseguridad, las organizaciones deben definir criterios claros para clasificar y priorizar incidentes, principalmente en función de dos aspectos clave: **el nivel de peligrosidad** y el **nivel de impacto**. La peligrosidad mide la amenaza potencial de un incidente, mientras que el impacto evalúa las consecuencias que tendría dicho incidente sobre los sistemas y operaciones de la organización. Ambos indicadores se utilizan para determinar la gravedad y el orden de respuesta ante los incidentes.

Niveles de peligrosidad

- Según la **Guía Nacional de notificación** y gestión de ciberincidentes, la peligrosidad de los incidentes se clasifica en cinco niveles, generalmente asociados a un código de colores. La clasificación refleja el grado de amenaza:



Nivel Crítico	Incluye amenazas de carácter avanzado y persistente, que representan el mayor nivel de peligrosidad
Nivel Muy Alto	Incorpora incidentes como malware dañino, intrusión con robo de información, y sabotaje de disponibilidad
Nivel Alto	Cubre incidentes de contenido abusivo (por ejemplo, contenido violento o inapropiado), ataques de denegación de servicio (DoS/DDoS), accesos no autorizados, phishing y compromiso de aplicaciones
Nivel Medio	Incluye incidentes de discurso de odio, ingeniería social, compromisos menores de cuentas y usos indebidos de recursos
Nivel Bajo	Incluye incidentes de menor riesgo como spam o escaneo de redes

Niveles de Impacto

- La importancia del impacto de cada incidente se mide por parámetros como la afectación a la seguridad nacional, la interrupción de servicios esenciales o las pérdidas económicas. Esta clasificación permite definir el grado de daño que el incidente podría causar a la organización y su entorno. Los niveles de impacto se detallan como:

Nivel Crítico	Afecta a la seguridad nacional o a infraestructuras críticas, con una interrupción significativa de los servicios (superior a 24 horas).
Nivel Muy Alto	Afecta a la seguridad ciudadana o a actividades oficiales, incluyendo daños reputacionales severos y el posible peligro para bienes.
Nivel Alto	Incidentes que afectan a más del 50% de los sistemas de la organización o que se extienden geográficamente
Nivel Medio	Afecta hasta un 20% de los sistemas y requiere una carga laboral moderada para su resolución
Nivel Bajo	Incidentes menores que afectan un número limitado de sistemas o servicios sin consecuencias graves. Estos eventos suelen solucionarse rápidamente y con pocos recursos.
Sin Impacto	Incidentes que no presentan afectación real sobre sistemas, datos o servicios, sin consecuencias tangibles para la organización o sus usuarios

Beneficios de un sistema de clasificación de incidentes

Un sistema de clasificación bien definido permite a la organización gestionar y priorizar incidentes de forma eficiente, destinando más recursos y atención a los casos más graves. También facilita el análisis de patrones y tendencias en los incidentes, optimizando la respuesta y permitiendo la implementación de medidas preventivas más efectivas.

3. Indicadores de compromiso

Definición

- Es un dato que surge producto de cierta actividad en nuestro sistema y que nos aporta información sobre el comportamiento, característica o descripción de una amenaza. En este sentido, un IoC funciona como evidencia que nos permite confirmar que nuestro equipo fue comprometido con malware, pero también es información que puede ser utilizada para prevenir futuros ataques.
- Los indicadores de riesgo (IoC) son información sobre un fallo de seguridad concreto que puede ayudar a los equipos de seguridad a determinar si se ha producido un ataque. Estos datos pueden incluir detalles sobre el ataque, como el tipo de malware utilizado, las direcciones IP implicadas y otros detalles técnicos.



Tipos habituales de IoC

- Hay varios tipos diferentes de IoC que pueden utilizarse para detectar incidentes de seguridad. Estos incluyen:
 - **Los IoC basados en la red**, como direcciones IP, dominios o URL maliciosos, también pueden incluir patrones de tráfico de red, actividad inusual del puerto, conexiones de red a hosts maliciosos conocidos o patrones de exfiltración de datos.
 - **Los IoC basados en el servidor** están relacionados con la actividad en una estación de trabajo o servidor. Los nombres de archivo o hash, las claves de registro o los procesos sospechosos que se ejecutan en el servidor son ejemplos de IoC basados en el servidor.
 - **Los IoC basados en archivos** incluyen archivos maliciosos, tales como malware o scripts.
 - **Los IoC de comportamiento** cubren varios tipos de comportamiento sospechoso, como comportamientos extraños de los usuarios, patrones de inicio de sesión, patrones de tráfico de red e intentos de autenticación.
 - **Los IoC de metadatos** tienen que ver con los metadatos asociados a un archivo o documento, como el autor, la fecha de creación o los detalles de la versión.

Clasificación de los indicadores

- Los loC se pueden también clasificar según su naturaleza y como se obtiene en:
 - **Atómicos:** los que no pueden ser descompuestos en partes más pequeñas sin perder su utilidad
 - **Calculados:** los que se derivan de datos implicados en un incidente, como el hash de un fichero
 - **Conductuales:** los que, a partir del tratamiento de los anteriores, permiten representar el comportamiento de un atacante. Por ejemplo, podemos averiguar que un grupo de atacantes utiliza la técnica del compromiso de la cadena de suministro (Supply Chain Compromise) para el acceso inicial a la red víctima, o que usa la técnica de modificación de las políticas de dominio (Domain Policy Modification) para hacer escala de privilegios.

Identificación de los loC

- La identificación de loC (Indicadores de Compromiso) se realiza a través de la monitorización de eventos de seguridad en sistemas y la aplicación de técnicas de análisis forense.
 - **Monitorización de Eventos de Seguridad:** Es el proceso fundamental que permite obtener información sobre situaciones que pueden comprometer la seguridad
 - **Creación de Reglas de Correlación y Casos de Uso:** La detección de loC se formaliza mediante la creación de reglas y casos de uso en plataformas de correlación de eventos, como los sistemas SIEM
 - **Técnicas Proactivas y Ciberinteligencia:** La identificación de loC de amenazas avanzadas requiere técnicas proactivas y el uso de inteligencia de amenazas, como, caza de amenazas o intercambio de información.
 - **Recopilación y Análisis Forense:** Una vez que el incidente ha ocurrido y se está en la fase de Respuesta, el análisis forense se utiliza para obtener loC detallados que confirmen la intrusión y ayuden en la erradicación

Creación de Reglas de Correlación y Casos de Uso

- La detección de loC se formaliza mediante la creación de reglas y casos de uso en plataformas de correlación de eventos, como los sistemas SIEM.
- **Casos de Uso:** Definen escenarios probables de ataque, permitiendo diseñar el modo de detección que debe utilizar el equipo de monitorización.
- **Reglas de Correlación:** Una vez diseñados los casos de uso, se implementan reglas en el SIEM. El proceso de creación pasa por varias fases:

1. Creación de hipótesis sustentadas en las TTP (Tácticas, Técnicas y Procedimientos) de los atacantes. Aquí se pueden usar matrices como MITRE ATT&CK como ayuda y base.
2. Identificación de las fuentes de datos necesarias para monitorizar la hipótesis.
3. Implementación y validación de la regla en el SIEM.

- **Las matrices MITRE ATT&CK** es una manera de describir y categorizar los comportamientos adversos basados en las observaciones de todo el mundo. ATT&CK es una lista de comportamientos conocidos de los atacantes que se recopilaron en tácticas y técnicas y se expresaron en matrices ; ofreciendo información sobre plataformas, grupos, herramientas utilizadas por los adversarios.

- La gran cantidad de información sobre ataques (y atacantes) que contiene puede ayudar a las organizaciones a determinar si están recopilando los datos correctos para detectar ataques de manera efectiva y evaluar qué tan bien están funcionando sus defensas actuales.

Reconnaissance 10 techniques	Resource Development 6 techniques	Initial Access 9 techniques	Execution 10 techniques	Persistence 18 techniques	Privilege Escalation 12 techniques	Defense Evasion 37 techniques	Credential Access 14 techniques	Discovery 25 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques	Impact 13 techniques
Active Scanning (02) Gather Victim Host Information (04) Gather Victim Identity Information (03) Gather Victim Network Information (04) Gather Victim Org Information (04) Phishing for Information (03) Search Closed Sources (02) Search Open Technical Databases (05) Search Open Websites/Domains (02) Search Victim-Owned Websites	Acquire Infrastructure (04) Compromise Accounts (02) Compromise Infrastructure (04) Develop Capabilities (04) Establish Accounts (02) Obtain Capabilities (04)	Drive-by Compromise (04) Exploit Public-Facing Application (02) External Remote Services (02) Hardware Additions (02) Phishing (02) Replication Through Removable Media (02) Supply Chain Compromise (02) Trusted Relationship (02) Valid Accounts (04)	Command and Control (04) BITS Jobs (02) Boot or Logon Autostart Execution (012) Inter-Process Communication (02) Native API (02) Scheduled Task/Job (04) Software Deployment Tools (02) System Services (02) User Execution (02) Windows Management Instrumentation	Account Manipulation (04) BITS Jobs (02) Boot or Logon Autostart Execution (012) Boot or Logon Initialization Scripts (04) Browser Extensions (02) Compromise Client Software Binary (02) Create Account (02) Create or Modify System Process (04) Event Triggered Execution (015) External Remote Services (02) Hijack Execution Flow (011) Indicator Removal on Host (04) Implant Container Image (02) Office Application Startup (04) Pre-OS Boot (04) Scheduled Task/Job (04) Server Software Component (02)	Abuse Elevation Control Mechanism (04) Access Token Manipulation (018) Boot or Logon Autostart Execution (012) BITS Jobs (02) Deobfuscate/Decode Files or Information (02) Direct Volume Access (02) Execution Guardrails (01) Exploitation for Defense Evasion (015) File and Directory Permissions Modification (02) Group Policy Modification (02) Hide Artifacts (07) Hijack Execution Flow (011) Process Injection (011) Indicator Removal on Host (04) Scheduled Task/Job (04) Valid Accounts (04) Indirect Command Execution (04) Masquerading (02) Modify Authentication Process (04) Modify Cloud Compute Infrastructure (04) Modify Cloud Server Software Component (02)	Abuse Elevation Control Mechanism (04) Access Token Manipulation (018) BITS Jobs (02) Deobfuscate/Decode Files or Information (02) Direct Volume Access (02) Execution Guardrails (01) Exploitation for Defense Evasion (015) File and Directory Permissions Modification (02) Group Policy Modification (02) Hide Artifacts (07) Hijack Execution Flow (011) Process Injection (011) Indicator Removal on Host (04) Impair Defenses (04) Steal or Forge Kerberos Tickets (04) Steal Web Session Cookie (02) Two-Factor Authentication Interception (02) Unsecured Credentials (04) Modify Cloud Compute Infrastructure (04)	Brute Force (04) Credentials from Password Stores (03) Exploitation for Credential Access (02) Forced Authentication (02) Input Capture (04) Man-in-the-Middle (02) Network Sniffing (02) OS Credential Dumping (08) Steal Application Access Token (02) Steal or Forge Kerberos Tickets (04) Steal Web Session Cookie (02) Two-Factor Authentication Interception (02) Unsecured Credentials (04) Software Discovery (01)	Account Discovery (04) Application Window Discovery (02) Browser Bookmark Discovery (02) Cloud Infrastructure Discovery (02) Cloud Service Dashboard (02) Cloud Service Discovery (02) Domain Trust Discovery (02) File and Directory Discovery (02) Network Service Scanning (02) Network Share Discovery (02) Network Sniffing (02) Password Policy Discovery (02) Peripheral Device Discovery (02) Permission Groups Discovery (02) Process Discovery (02) Query Registry (02) Remote System Discovery (02) Software Discovery (01)	Exploitation of Remote Services (02) Internal Spearphishing (02) Lateral Tool Transfer (02) Remote Service Session Hijacking (02) Remote Services (04) Replication Through Removable Media (02) Software Deployment Tools (02) Taint Shared Content (02) Use Alternate Authentication Material (04)	Archive Collected Data (02) Audio Capture (02) Automated Collection (02) Clipboard Data (02) Data from Cloud Storage Object (02) Data from Configuration Repository (02) Data from Information Repositories (02) Data from Local System (02) Data from Network Shared Drive (02) Data from Removable Media (02) Data Staged (02) Email Collection (02) Input Capture (04) Man in the Browser (02) Man-in-the-Middle (02) Screen Capture (02) Video Capture (02)	Application Layer Protocol (04) Communication Through Removable Media (02) Data Encoding (02) Data Obfuscation (02) Dynamic Resolution (02) Encrypted Channel (02) Fallback Channels (02) Ingress Tool Transfer (02) Multi-Stage Channels (02) Non-Application Layer Protocol (02) Non-Standard Port (02) Protocol Tunneling (02) Proxy (04) Remote Access Software (02) Traffic Signaling (02) Web Service (02)	Automated Exfiltration (011) Data Transfer Size Limits (02) Data Destruction (02) Data Encrypted for Impact (02) Exfiltration Over Alternative Protocol (02) Exfiltration Over C2 Channel (02) Exfiltration Over Other Network Medium (04) Exfiltration Over Physical Medium (01) Exfiltration Over Web Service (02) Scheduled Transfer (02) Transfer Data to Cloud Account (02) System Shutdown/Reboot (02)	

Técnicas Proactivas

- **Threat Hunting (Caza de Amenazas):** Es el proceso de búsqueda iterativa y proactiva a través de diferentes fuentes para la detección y aislamiento de amenazas avanzadas que han logrado evadir las soluciones de seguridad existentes.
- **Modelado de Ciberamenazas:** Las Unidades de Ciberinteligencia tienen como objetivo obtener las diferentes TTP (Tácticas, Técnicas y Procedimientos) de los atacantes para definir una estrategia de defensa. El comportamiento de un atacante puede ser representado por un IoC de tipo conductual (por ejemplo, el uso de la técnica de modificación de las políticas de dominio para escalar privilegios)
- **Vigilancia Digital:** Consiste en identificar posibles amenazas que afecten de forma corporativa, como la monitorización de aplicaciones falsas o el seguimiento de grupos de hackers.

- **Intercambio de Información:** El intercambio de información de seguridad con terceros (como otros CERT/CSIRT, o el CCN-CERT/INCIBE-CERT) proporciona indicadores de compromiso y alertas tempranas sobre nuevos ataques o vulnerabilidades

4. Estrategias proactivas para prevenir incidentes de seguridad

Monitorización de Eventos de Seguridad y Fuentes de Datos

- La identificación de IoC se realiza analizando los registros de los dispositivos internos de la organización, conocidos como Fuentes Internas de Datos.
- **Sistemas de Detección de Intrusos (IDS/IPS):**
 - **NIDS (Sistemas de Detección de Intrusos en Red):** Supervisan segmentos de red. Utilizan bases de datos de "firmas" de ataques conocidos para diferenciar un uso normal de uno fraudulento. Las estrategias que siguen incluyen la Detección de patrones (basada en el conocimiento de ataques anteriores) y la Detección de anomalías en los protocolos de red.
 - **HIDS (Host IDS):** Supervisan el comportamiento de un sistema o dispositivo concreto en busca de anomalías. Estos incluyen subsistemas como el LFM (Log File Monitor), que supervisa y registra eventos en archivos de registro (logs)
- **EDR (Endpoint Detection and Response):** Estos sistemas se utilizan para detectar ataques sofisticados. Combinan análisis y bloqueo de comportamientos, control de listas blancas/negras, y monitorización de la red.
- **Análisis del Tráfico de la Red:** Se buscan anomalías y usos indebidos en flujos de comunicación como HTTP/S, DNS y SMTP, así como detecciones de named pipes anómalas o usos indebidos de RDP (Remote Desktop Protocol).
- **Análisis de Payload:** Consiste en el análisis de *malware* en tiempo real, idealmente antes de que llegue a la víctima (consolas de antivirus, o herramientas anti-rootkits).
- **Honeypots Internos (Sistemas de Engaño):** Estos sistemas están diseñados para engañar o confundir a posibles atacantes, simulando vulnerabilidades o activos falsos. Su objetivo es aprender tácticas, técnicas y procedimientos (TTP) de los atacantes y funcionar como sistemas de detección de intrusiones tempranas.

Procedimientos de Respuesta

- Cuando tenemos que preparar un proceso de respuesta ante un incidente, es como si tuviéramos que realizar un pequeño procedimiento o manual de que debe hacer una persona en concreto cuando esto pase. El informe debe contener los siguientes campos:
 - Introducción y objetivos del documento
 - Alcance
 - Descripciones básicas sobre cuál es el incidente de forma resumida
 - Dependiendo de la taxonomía en como se clasifiquen los incidentes de una empresa pues deberemos tener unos criterios para identificar que tipo de incidente se trata.
 - También se debe evaluar la urgencia de resolución de ese incidente.
 - Y en el informe debe aparecer el equipo implicado que ha detectado ese incidente y el equipo que debe darle respuesta

Simulacros (Role-play) y Ciberejercicios

- Es fundamental poner a prueba a través de simulacros o ciberejercicios los procedimientos operativos definidos para la gestión de incidentes para poder validar su funcionamiento; la autoevaluación tanto de los procedimientos como del propio equipo de respuesta ayuda a establecer un proceso de mejora continua y entrenar las capacidades de una empresa para afrontar los incidentes y ejercitar la toma de decisiones.
- Los simulacros deben de ser periódicos y se llevan a cabo bajo distintos escenarios e intentando involucrar al mayor número de personas posibles tanto del ERI como todos los actores de interés
- Al finalizar el ejercicio de ciberseguridad el equipo siempre debe responder a unas preguntas similares a las siguientes:
 - ¿Hemos fallado?
 - ¿Se podría haber hecho de forma más ágil o de una mejor forma?
 - ¿Se ha seguido el procedimiento establecido?
 - ¿Se ha detectado la intrusión?
 - ¿Se ha llevado a cabo de forma proporcional la contención del incidente?

Equipos de Seguridad

- **Blue team**: Es el equipo principal de la organización, en cuanto la infraestructura y los procesos tecnológicos. Este se encarga del bastionado de los entornos, la monitorización y detección de incidentes y las respuestas de seguridad

- **Red team**: Este equipo está especializado en el funcionamiento de las amenazas. No solo ponen a prueba la seguridad lógica, sino que son capaces de poner a prueba tanto la seguridad física como el conocimiento del usuario a través de técnicas de ingeniería social
- **Purple team**: Equipo especializado en ciberejercicios, entrenamiento y formación para el BlueTeam. La filosofía Purple Team puede materializarse de muchas formas, desde ejercicios esporádicos hasta un programa de auditoría continua, retroalimentando con nueva inteligencia de amenazas y lecciones aprendida



Prevención y concienciación

- La ciberseguridad engloba todos los elementos, ya sean técnicos, humanos, materiales u organizativos. El empleado debe convertirse en parte activa de la estrategia de defensa de una empresa, teniendo capacidades tanto para saber utilizar la información y medios digitales que maneja de forma segura como para saber identificar y notificar situaciones anómalas.
- El primer paso es capacitar al empleado a través de acciones continuadas de concienciación, formación y ciberejercicios en entornos de simulación
- Las organizaciones deben desarrollar por tanto planes de prevención y concienciación en ciberseguridad, estableciendo normas y medidas de protección:
 - Definiendo los principios generales de la organización en materia de ciberseguridad
 - Estableciendo una normativa de protección del puesto de trabajo
 - Definiendo un plan de concienciación a empleados.
 - Desarrollando el material necesario para llevar a cabo las acciones de concienciación dirigidas a empleados

5. Elaboración de informes sobre incidentes

Registro de incidentes

- La organización debe mantener un registro de todos los eventos de seguridad significativos, bien sean autodetectados por los sistemas internos o externos de monitorización, o a través de reportes de usuarios de terceros, con independencia de si se materializan o no en incidentes de ciberseguridad
- **Que debemos registrar ante un incidente:**
 - Identificador único del incidente
 - Identificación del origen del reporte; como se ha detectado, bien sea a través de la plataforma de monitorización de eventos de seguridad o un reporte de un tercero.
 - Momentos (mediante timestamp) en los que se produce el incidente, se detecta y es notificado.
 - Clasificación inicial y criticidad del incidente
 - Descripción inicial del incidente
 - Cualquier otro dato adicional que pueda ser relevante en la gestión del incidente
- **¿Como podemos elaborar un informe?**
 - **ELABORACIÓN DE TICKETS:** Una de las aproximaciones habituales para cumplir este requisito es el uso de soluciones software basadas en una solución SIEM en la que se registran todos los eventos de seguridad significativos en forma de tickets.

Estrategia de comunicación

- En los incidentes más críticos es fundamental establecer la estrategia de comunicación en función del tiempo o prioridad y grupo al que va dirigida.
- ¿qué tipo de información se va a ofrecer? ¿Cuáles son los mensajes clave? ¿Que formato se utilizara para la difusión de la comunicación? ¿Qué canales o medios se usarán?
- Es importante que la organización sea proactiva y ágil a la hora de comunicar la situación, ya que hay que tener en cuenta posibles filtraciones de información (voluntarias o no) por parte de empleados, proveedores, clientes, ... Sobre lo que está sucediendo, corriendo el riesgo de que sea información incompleta, a destiempo, o errónea maximizando así el impacto del propio incidente de la organización
- Los mensajes a comunicar deberían tener las siguientes características:
 - Ofrecer un discurso unificado y a ser posible por una única fuente oficial de información Transparencia, empatía y asunción de responsabilidades.

- Nunca se debe mentir y ofrecer la información de forma precisa.
- Para proteger la reputación de la organización debe evitarse cualquier tipo de incertidumbre, pero también tener en cuenta que la información que se ofrezca debe ser la correcta.
- Es importante transmitir confianza, actuar con serenidad, firmeza y profesionalidad
- Demostrar atención y respeto hacia todos los involucrados
- Puesta en valor de las acciones adoptadas.
- Cualquier situación de crisis representa una oportunidad para demostrar la capacidad de la organización para solventar una situación compleja, mostrando que la gestión del evento disruptivo está siendo la adecuada

6. Conceptos básicos del análisis forense

Métodos

- En ocasiones es necesario llevar a cabo un análisis forense de los activos comprometidos. Existen diferentes metodologías, aun así se basan en el mismo concepto del propio incidente que es la recolección de información y su análisis.
- El dispositivo a analizar contiene las evidencias digitales que permitirán al investigador forense digital determinar cuándo y cómo tuvo lugar el ataque. Adicionalmente, podrían obtenerse evidencias que demostrarán quién, qué, dónde y por qué realizó el ataque.
- Existen dos formas de adquisición de evidencias:
 - Evidencias en equipos encendidos
 - Evidencias en equipos apagados

Dispositivos encendidos

- Ocurre cuando el dispositivo a analizar está encendido y ejecutando su propio sistema operativo.
- Uno de los objetivos clave es capturar la memoria RAM y registros caché. Ambos datos se perderían inmediatamente si se apaga el equipo (claves de cifrado, conexiones activas, contraseñas en texto claro).
- Es fundamental en casos de código dañino (malware) o intrusiones activas, donde el proceso malicioso reside en memoria.
- Se deben utilizar herramientas que alteren lo menos posible el sistema (minimización de la huella forense) para volcar la RAM a un almacenamiento externo.

- El orden de la adquisición de evidencias viene determinado por el orden de volatilidad, que es el inverso de persistencia:
 - Registros y caché del procesador
 - Memoria RAM
 - Red (tablas de enrutamiento, cache ARP,...)
 - Tabla de procesos den ejecución
 - Tráfico de red
 - Archivos temporales del sistema de ficheros
 - Sistema de ficheros del almacenamiento del dispositivo
 - Configuración física de una red
 - Cintas, disquetes, memoria USB, soportes ópticos.

Dispositivos apagados

- Ocurre cuando el dispositivo está apagado.
- El objetivo es realizar una copia exacta, clonado, del disco duro del dispositivo.
- Al estar apagado se han perdido la información más volátil como la memoria RAM.
- Métodos de acceso:
 - Extracción física: Se retira el disco duro y se conecta a una clonadora.
 - Arranque con entorno externo (Boot Live USB): Se utiliza un sistema operativo forense en una unidad externa (USB/CD) para arrancar el equipo. Aunque encendemos la máquina, no arrancamos el sistema operativo del sospechoso, sino el nuestro, solo para acceder al disco duro. No podemos ver la RAM original del usuario.
- Pasos eficaces para realizar un análisis forense en dispositivos apagados:
 - Antes de comenzar el proceso de clonado forense de la evidencia, el soporte de almacenamiento destino debe ser sometido a un proceso de borrado seguro.
 - Utilizar **write blockers**, evitando que se puedan producir modificaciones en ella durante el proceso de clonado forense.
 - Efectuar un **resumen digital (hash)** de la información contenida en el soporte de almacenamiento original de forma simultánea al proceso de clonado u obtención de la imagen a bajo nivel.
 - Efectuar el **cálculo del valor del hash** de la información contenida en el soporte destino donde se realizó el clonado forense utilizando los mismos algoritmos de resumen empleados con la evidencia original.

- **Comprobar que los valores de los hashes obtenidos de la evidencia original y de la copia forense coinciden**
, lo cual garantiza la integridad de los datos almacenados en la copia forense

Cadena de custodia

- Los analistas deberán trabajar en todo momento trabajar con —salvo casos muy excepcionales— con copias de las evidencias y jamás sobre las originales, puesto que serían alteradas y, por tanto, invalidadas. En cualquier caso, la copia debe ser exacta, bit a bit, es por ello que de la copia segura se debe obtener un valor hash de ambas evidencias para poder compararlas.
- Es importante preservar la cadena de custodia de los datos a analizar; una cadena de custodia es un registro documental de quien estaba en posesión y control de una determinada evidencia en cada momento, hasta que dicha evidencia **es presentada ante un tribunal**

Análisis de la evidencia digital

- Una clasificación habitual de las diferentes formas en las que un analista forense puede analizar una evidencia digital es la siguiente:
 - **Análisis temporal:** Determina la actividad a nivel de archivo ocurrida en el dispositivo de una determinada horquilla temporal, examinando diferentes archivos de eventos del sistema para relacionar las actividades del sistema de ficheros con otras actividades.
 - **Análisis de información oculta:** Busca información oculta ya sea en el sistema de ficheros o en partes de disco normalmente inaccesibles al acceso estándar del sistema de ficheros
 - **Análisis de aplicaciones y archivos:** Busca el contenido de archivos, relaciona archivos con aplicaciones y actividad de aplicaciones con la creación y eliminación de archivos.
 - **Análisis de propiedad y posesión:** Ayuda a identificar actividades relacionadas con la actividad de una determinada cuenta de usuario

Análisis del malware

- Se considera malware cualquier tipo de software dañino contra el normal funcionamiento de un dispositivo, aplicación o red. El análisis de malware es el arte de diseccionar un software malicioso para comprender su funcionamiento, caracterizarlo y obtener indicadores de compromiso para su identificación en otros sistemas o determinar el método de eliminación de un dispositivo comprometido.

- Existen diversas técnicas para llevar a cabo el análisis de una determinada muestra de malware. Estas técnicas, ordenadas de menor a mayor complejidad, se pueden resumir en:
 - **Análisis estático del malware:** Se trata de una primera aproximación a un fichero sospechoso. Abarca las investigaciones realizadas sobre el objeto que contiene el código dañino sin ejecutarlo o desensamblarlo. Consiste en examinar las propiedades estáticas de dicho archivo como cadenas de texto, hash, posibles recursos embebidos ...
 - **Análisis dinámico o comportamental del malware:** El analista debe utilizar un entorno de pruebas aislado que le permita infectar un sistema (generalmente máquina virtual) con el malware objeto de estudio para observar su comportamiento como si se tratase de un sistema en producción. Se podrá analizar cómo el software malicioso interactúa con el entorno o qué comunicaciones externas genera.
 - **Reversing del código del malware:** Realizar la ingeniería del código de la muestra malware puede aportar un conocimiento adicional muy valioso a la información ya obtenida en el análisis dinámico.
 - Este tipo de análisis implica la utilización de un desensamblador y un depurador, además de una amplia variedad de plugins y herramientas específicas para automatizar algunos aspectos del análisis. El análisis forense de memoria RAM también suele resaltar de ayuda en esta fase de análisis de malware

Recursos materiales

- Los equipos de respuesta ante incidentes deben disponer de los medios adecuados para llevar a cabo un análisis forense. Es por ello que los equipos deben ser de altas prestaciones.
- En otros muchos casos el propio equipo pues debido a la complejidad del incidente debe de desplazarse in situ. Para ello deben de disponer de medios como portátiles seguros, dispositivos de gran almacenamiento, S.O. externos, checklist impresas, cámaras de fotos...